SRC Project 02 - Report

Danilo Silva nº113384, Guilherme Santos nº113893

1. Training Data Analysis

The dataset used was dataset number 7, computed as $(113384 + 113893) \bmod 10 = 7$. This section describes the analysis of the training data (`internal_train7.json` and `external_train7.json`) used to set the baseline that was used to define all rule thresholds.

1.1. Private Network

All source IPs belong to `192.168.0.0/16`, specifically `192.168.107.0/24`, with 194 unique internal IPs.

1.2. Internal Servers

Four internal servers were identified, all contacted by every internal client:

IP	Port	Proto	Service	Flows
192.168.107.224	53	UDP	DNS	54,943
192.168.107.230	53	UDP	DNS	54,489
192.168.107.225	443	TCP	HTTPS	80,384
192.168.107.235	443	TCP	HTTPS	81,073

Table 1: Internal servers identified in training data.

1.3. Internal User Traffic

Global dataset statistics across 194 internal clients:

- Total flows: min 193, median 4,617, std 2,173, max 11,082
- Unique destination IPs: min 23, median 125, std 43, max 236
- Up/down bytes ratio: median 0.11, consistent across all IPs
- DNS flows per IP: min 24, median 558, P95 1,040, P99 1,131, max 1,350
- DNS/HTTPS flow ratio: median 0.14, std 0.01, max rel. dev. 40.81%, max 0.1935
- DNS mean upload bytes per flow: median 199.9, std 3.47, max 212.6
- HTTPS up/down bytes ratio: median 0.108, std 0.003, max rel. dev. 6.45%, max 0.114
- Inter-flow interval CV (coefficient of variation, std / mean): median 14.44

Destination countries (36 total): AE, AT, AU, BE, BH, BR, CA, CH, CL, CN, DE, ES, FR, GB, HK, ID, IE, IL, IN, IT, JP, KR, MX, MY, NL, NO, PH, PT, RO, SA, SE, SG, TH, TW, US, ZA. Top three by flow count: PT, US, CA.

For each IP, the interval CV, DNS flow count, destination country set, and median flow count per destination were stored as behavioral baselines.

1.4. External User Traffic

External users (194 IPs in `188.83.78.0/24`) access corporate servers (`200.0.0.0/24`) exclusively via port 443 (HTTPS).

- Up/down bytes ratio: 0.12 across all IPs
- Inter-flow interval CV: P5 3.70, P10 3.72, median 12.85
- Off-hours activity (flows between 0h and 6h): P95 0.30%, P99 13.45%

For each external IP, its training CV and off-hours percentage were stored as individual baselines.

2. Rules Definition

Each rule below uses thresholds derived exclusively from the training data (Section 1). Global population statistics are applied uniformly. Per-IP baselines are compared against each device's own training behavior when noted.

2.1. Internal BotNet Activity

Botnet devices often communicate peer-to-peer inside the network, bypassing central servers and, normally, have machine-like behavior. During training, no internal host ever contacted another internal host beyond the four known servers. Any such contact is anomalous by construction. The traffic timing regularity check filters out accidental single contacts by requiring the P2P communication to be at least twice as regular as the device's own normal traffic, consistent with automated machine-to-machine communication rather than human activity.

Signal	Condition
Internal P2P contacts	dst_ip in 192.168.107.0/24, not a known server
P2P interval regularity	P2P CV $<$ 0.5 $\times$ per-IP training CV

Table 2: BotNet rule: flags IPs communicating with other internal hosts beyond the four known servers while, at the same time, looking for automated machine-to-machine behavior.

2.2. Data Exfiltration via HTTPS and/or DNS

Data exfiltration via DNS tunneling increases the proportion of DNS traffic relative to HTTPS, producing an abnormally high DNS/HTTPS flow ratio. The threshold is set at 5 times the maximum relative deviation observed across all IPs in training (40.81%), ensuring only structural shifts in traffic composition are flagged. For DNS, a P99 volume check (1,131 flows) ensures the IP is not only ratio-anomalous but also in the top 1% of DNS flow volume. For HTTPS, the up/down ratio alone is sufficient: the training distribution is extremely tight (std 0.003, max 0.114), so exceeding 0.1434 reflects a genuine shift from download-heavy to upload-heavy behavior as an exfiltration via HTTPS is.

Signal	Condition
DNS/HTTPS flow ratio	test ratio $>$ median $+$ 5$\times$ max relative deviation (40.81%)
DNS flow volume	test flows $>$ P99 training (1,131)
HTTPS up/down ratio	test ratio $>$ median $+$ 5$\times$ max relative deviation (6.45%)

Table 3: Exfiltration rule: DNS requires both ratio anomaly AND volume above P99. HTTPS uses ratio anomaly alone.

2.3. C&C Activities via DNS

Command-and-control via DNS uses periodic queries (beaconing) to poll for instructions. Unlike DNS exfiltration, which floods the channel with data, beaconing keeps the DNS/HTTPS ratio normal while increasing DNS query frequency. The rule requires a DNS flow surge above training P95 (1,040) and 3 times the device's own training volume, combined with a DNS interval CV that drops below half the device's normal CV. Mutual exclusivity with the exfiltration rule is enforced by requiring the DNS/HTTPS ratio to remain below the exfiltration threshold, since a high ratio indicates tunneling, not beaconing.

Signal	Condition
DNS flow surge	test flows > P95 training (1,040) AND > 3× per-IP training
DNS interval regularity	test CV < 0.5 × per-IP training CV
DNS/HTTPS flow ratio	test ratio < median + 5× max relative deviation (40.81%)

Table 4: C&C DNS rule: detects beaconing (high amount of periodic DNS queries with normal DNS/HTTPS ratio).

2.4. Anomalous External Destinations

A device contacting a country that no IP in the organization ever accessed during training is suspicious. To filter noise, the rule requires the flow count to the new IP of a new country to exceed that device's own median per-destination (IP) flow count from training. If there is at least one destination IP where both of this happens, the rule flags.

Signal	Condition
New country contacted	country not in global training set (36 countries)
Flow volume to new country	flows > per-IP median destination flow count

Table 5: Anomalous destinations: flags IPs contacting countries never seen by any device in training, with flow counts exceeding that device's own per-destination median.

2.5. External User Behavior

External users accessing corporate services at unusual hours with machine-like regularity suggests automated abuse. Off-hours are defined as flows between 0h and 6h. The rule requires both the off-hours percentage to exceed P95 training (0.30%) and the interval CV to fall below P10 training CV (3.72), meaning the user is both active at night and more regular than 90% of all users in training.

Signal	Condition
Off-hours activity	test off-hours % > P95 training (0.30%), flows between 0h–6h
Access regularity	test CV < P10 training CV (3.72)

Table 6: External users: Catches IPs combining nighttime activity with unusually regular access patterns machine-like.

3. Results

The rules defined in Section 2 were applied to the test datasets and 21 internal IPs and 2 external IPs were flagged as anomalous across all five rules. Table 7 lists every flagged device with its measured values and the rule group that detected it.

IP	Values
BotNet – P2P CV $<$ 0.5× train CV	
192.168.107.29	P2P to .149,.159,.81, CV 1.44 $<$ 4.48
192.168.107.149	P2P to .29,.159,.81, CV 1.39 $<$ 4.72
192.168.107.159	P2P to .29,.149,.81, CV 1.38 $<$ 4.12
192.168.107.81	P2P to .29,.149,.159, CV 1.53 $<$ 18.43
Exfil DNS – ratio $>$ 0.413, flows $>$ 1,131	
192.168.107.116	ratio 0.598, flows 2,149
192.168.107.152	ratio 13.141, flows 31,775
192.168.107.16	ratio 0.581, flows 3,060
192.168.107.181	ratio 10.093, flows 30,520
192.168.107.50	ratio 10.637, flows 59,737
Exfil HTTPS – ratio $>$ 0.1434	
192.168.107.126	ratio 0.5540
192.168.107.190	ratio 0.3019
192.168.107.40	ratio 13.4171
192.168.107.82	ratio 9.9937
192.168.107.98	ratio 18.5138
C&C DNS – flows $>$ 1,040, CV ratio $<$ 0.5	
192.168.107.36	flows 1,245 (train 392), CV ratio 0.32
192.168.107.45	flows 1,433 (train 380), CV ratio 0.35
192.168.107.79	flows 1,227 (train 402), CV ratio 0.47
Anomalous Destinations – new country, flows $>$ per-IP median	
192.168.107.145	NZ (1 IP), flows per IP 7 (train median 6)
192.168.107.153	FI, RU (9 IPs), flows per IP 7–11 (train median 6)
192.168.107.157	IR, RU, TR (21 IPs), flows per IP 6–8 (train median 5)
192.168.107.34	IR, RU (5 IPs), flows per IP 8–10 (train median 8)
External Users – off-hours $>$ 0.30%, CV $<$ 3.72	
188.83.78.86	off 1.75%, CV 0.24
188.83.78.99	off 11.48%, CV 3.70

Table 7: All flagged devices. 21 internal and 2 external IPs.

3.1. Acknowledgements

We acknowledge that the UEBA rules may produce false positives due to the limited training data (one day) and the inherent overlap between normal traffic variation and anomalous behavior. In a production deployment with multi-day baselines, the confidence of each detection could be more precisely assessed.

Based on the magnitude of the deviations, if this were on a more advanced system, we would split the flagged devices into two groups: **block** (high confidence, immediate action recommended) and **monitor** (lower confidence, requires investigation before action).

Devices to block

- `192.168.107.29, .149, .159, .81` (BotNet) – P2P cluster with zero training precedent
- `192.168.107.152, .181, .50` (Exfil DNS) – ratio 10-13, far above threshold 0.413
- `192.168.107.40, .82, .98` (Exfil HTTPS) – ratio 9-18, far above threshold 0.1434
- `192.168.107.36, .45, .79` (C&C DNS) – all three beaconing candidates
- `192.168.107.153, .157, .34` (Anom. Dest) – contacts with Russia and Iran
- `188.83.78.86, .99` (External) – both combining off-hours with unusual regularity

Devices to monitor

- `192.168.107.116, .16` (Exfil DNS) – ratios 0.58 and 0.60 are above the 0.413 threshold but substantially lower than the other flagged IPs (10-13), making them less conclusive

- `192.168.107.126, .190` (Exfil HTTPS) – ratios 0.55 and 0.30 are above the 0.1434 threshold but far below the other flagged IPs (9-18)
- `192.168.107.145` (Anom. Dest) – only contacted New Zealand via a single IP, a less suspicious destination than the other flagged countries (Russia, Iran)

4. SIEM Integration

The UEBA module sends alerts to the local syslog daemon using Python's `syslog` module. Each flagged device generates one syslog entry with the process name `ueba`, facility `LOG_ALERT`, and a message containing the IP, rule name, and detection details. A Wazuh agent running on the same machine could read these entries from the local journal and forward them to the Wazuh manager, where they would be indexed and surfaced as security alerts without additional configuration.

The integration requires the following lines of code:

```
import syslog
syslog.openlog('ueba', logoption=syslog.LOG_PID)
syslog.syslog(syslog.LOG_ALERT, f'{ip} [{rule}] {details}')
```

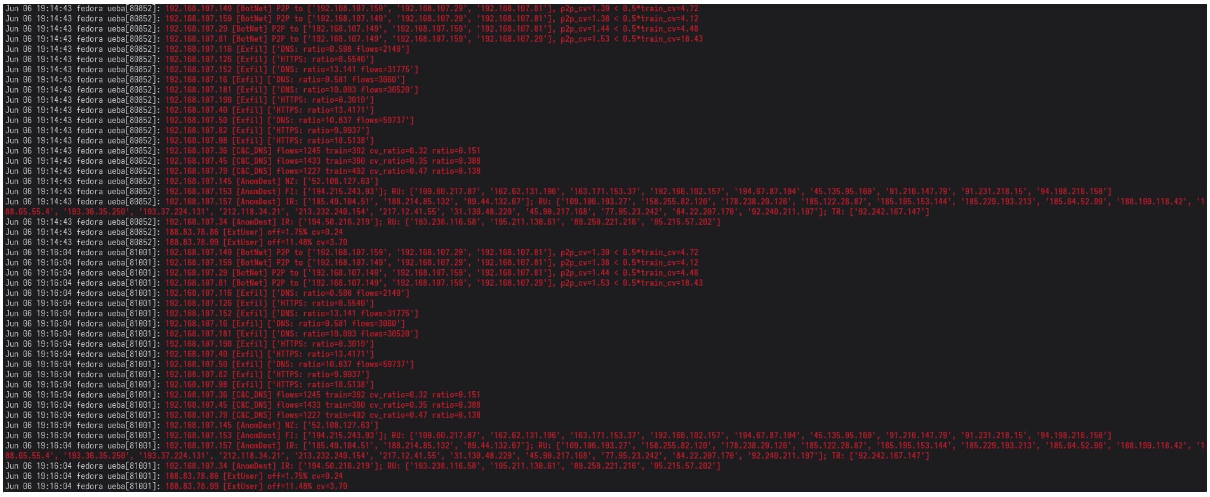

Figure 1: UEBA alerts seen in syslog output via journalctl.